ELMS-010 — Account / Username Enumeration

Attribute	Detail
Finding ID	ELMS-010
Severity	Low
CVSS 4.0	3.1 — CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N
OWASP 2021	A07 — Identification & Authentication Failures
CWE	CWE-204, CWE-203, CWE-200
Affected component	forgot-password.php; admin/check_availability.php (admin AJAX)
Parameters	empid, emailid
Auth context	Recovery oracle: none · Availability oracle: admin session
Status	Confirmed

Description & Root Cause

`forgot-password.php` branches observably on identity validity — a valid `(EmpId, email)` pair returns a password-change form, an invalid one returns `Invalid details`. The admin `check_availability.php` endpoint explicitly reports whether an Employee-ID/email already exists. Either oracle lets an attacker confirm which identities are registered, because responses expose existence state instead of a uniform result.

Business Impact

An attacker builds a verified list of valid employees/emails, increasing the success and stealth of the token-less reset (ELMS-002), targeted phishing and credential attacks.

Proof of Concept — Step by Step

Step 1 — Submit a valid pair -> response contains `change your password`.

Step 2 — Submit the same EmpId with a wrong email -> response contains `Invalid details`.

Step 3 — Script the distinction to enumerate valid identities (the recovery oracle needs no authentication).

```
[FIGURE 1 - SUGGESTED CAPTURE]
Tool   : Burp Intruder / a shell loop
Screen : two stacked responses for forgot-password.php
Red box: valid pair -> "change your password"  vs  invalid -> "Invalid details"
         (the observable difference that leaks identity existence)
```

Exploit payload:

```
# valid vs invalid oracle
curl -s -d 'empid=7856214&emailid=jhn12@gmail.com&submit=Reset' .../forgot-password.php | grep -q
'change your password' && echo VALID
curl -s -d 'empid=7856214&emailid=wrong@nope.com&submit=Reset'  .../forgot-password.php | grep -q
'Invalid details'     && echo INVALID
```

HTTP Evidence

`evidence/responses/09_reset_valid.resp` -> `change your password`; `09_reset_invalid.resp` -> `Invalid details`.

Remediation

Return a uniform, non-committal response for recovery regardless of match ("If the details match an account, a reset link has been sent"). Genericise and rate-limit `check_availability.php`. Add anti-automation (rate limiting / CAPTCHA) to both endpoints.

```
process_reset_if_exists($empid, $email);                  // emails only on a real match
echo "If the details match an account, a reset link has been sent.";   // identical for all inputs
```

Re-test Procedure

Send valid and invalid pairs -> expect an identical generic message for both; confirm rate-limiting on repeated requests.

Exploitation Feasibility

Easy and scriptable; the recovery oracle needs no authentication.

Existing CVE Verification

No CVE (behavioural/design). Status: **No matching CVE identified**.

References

- OWASP WSTG-IDNT-04 (Account Enumeration); CWE-204.

Conclusion

Confirmed enumeration oracles via recovery and availability endpoints. Low severity; genericise responses and add anti-automation.